

Zenith Global Inc. Governance Framework Flow- ERD Diagram

By: Matt Watkins, GRC Analyst/Advisor

The diagram below details how security risks, vulnerabilities, and policy exceptions move through Zenith Company's governance pipeline.

```
erDiagram
    ASSET {
        string asset_id PK
        string asset_name
        string asset_type
        string owner_email
        string criticality_tier
    }

    RISK {
        string risk_id PK
        string asset_id FK
        string title
        string source_type
        date identified_date
        string status
    }

    ASSESSMENT {
        string assessment_id PK
        string risk_id FK
        string assessor_name
        int likelihood_score
        int impact_score
        int risk_score
        string severity_level
        date assessed_date
    }

    TREATMENT_DECISION {
        string decision_id PK
        string assessment_id FK
        string strategy
        string approved_by
        date decision_date
    }

    REMEDIATION_TASK {
        string task_id PK
        string decision_id FK
        string jira_ticket_ref
        string assignee
        date sla_due_date
        string execution_status
    }
```

```
POLICY_EXCEPTION {
  string exception_id PK
  string decision_id FK
  string justification
  string risk_owner_signoff
  date expiration_date
  string approval_status
}
```

```
%% Entity Relationships
ASSET ||--o{ RISK : "has identified"
RISK ||--|{ ASSESSMENT : "undergoes"
ASSESSMENT ||--|| TREATMENT_DECISION : "requires"
TREATMENT_DECISION ||--o| REMEDIATION_TASK : "results in (Mitigate)"
TREATMENT_DECISION ||--o| POLICY_EXCEPTION : "results in (Accept/Avoid)"
```

Entity Relationship Mapping Breakdown

- **ASSET to RISK (1 : N):** An IT asset (e.g., a server, database, or application) can have multiple security risks or compliance gaps mapped to it over time.
- **RISK to ASSESSMENT (1 : N):** Each risk record undergoes one or more evaluations over its lifecycle to update its qualitative/quantitative scoring.
- **ASSESSMENT to TREATMENT_DECISION (1 : 1):** A completed risk assessment forces a single formal governance decision (Mitigate, Transfer, Accept, or Avoid).
- **TREATMENT_DECISION to REMEDIATION_TASK (1 : 0..1):** If the decision is **Mitigate**, the workflow creates an actionable task tied directly to an operational tracking system (like Jira).
- **TREATMENT_DECISION to POLICY_EXCEPTION (1 : 0..1):** If the decision is **Accept** or **Avoid**, the workflow routes the risk to executive leadership (Mark Daleman / CISO) for explicit risk sign-off and sets an automated expiration date.

